Lecture Notes S04: Cơ chế Thu hồi & Phân tích Trạng thái Chứng chỉ

Học phần: Cơ sở hạ tầng khóa công khai (ATHK 512) · Lớp CHAT4P
Giảng viên: Nguyễn An Khương (Khoa Khoa học & Kỹ thuật Máy tính, Trường ĐHBK Tp. HCM)
Trợ giảng: Nguyễn Hữu Hoàng Huy

---

1. Bản chất Kỹ thuật của OCSP Stapling

Trong cơ chế OCSP truyền thống, mỗi khi người dùng truy cập một website, trình duyệt phải gửi yêu cầu HTTP tới máy chủ OCSP Responder của CA. Điều này dẫn tới 2 điểm yếu lớn: 1. **Quyền riêng tư (Privacy Leak):** CA nắm được toàn bộ lịch sử duyệt web và địa chỉ IP của người dùng. 2. **Hiệu năng & Khả năng sẵn sàng (Latency & Soft-fail):** Nếu máy chủ OCSP bị tấn công từ chối dịch vụ hoặc phản hồi chậm, trình duyệt sẽ bị treo hoặc buộc phải bỏ qua kiểm tra (Soft-fail), khiến cơ chế thu hồi bị vô hiệu hóa.

OCSP Stapling khắc phục triệt để: Máy chủ web định kỳ (ví dụ mỗi giờ) truy vấn lấy phản hồi OCSP đã ký của chính nó, lưu vào bộ đệm cache. Khi client kết nối, máy chủ "ghim" phản hồi này vào bản tin `CertificateStatus` trong quá trình bắt tay TLS 1.3.

---

2. Kiểm định Tính Tuân thủ X.509 với ZLint

ZLint là công cụ tiêu chuẩn công nghiệp do ZMap Project phát triển, chứa hàng trăm bộ quy tắc kiểm tra nghiêm ngặt đối chiếu với RFC 5280 và CA/B Forum Baseline Requirements: * Kiểm tra tính hợp lệ của Serial Number (phải có từ 64 đến 159 bit ngẫu nhiên). * Kiểm tra thời hạn không vượt quá quy định (hiện hành tối đa 398 ngày). * Kiểm tra các trường mở rộng bắt buộc và cấm đối với từng loại chứng chỉ. * Đánh giá mức độ cảnh báo: `NE` (Notice), `WA` (Warning), `ER` (Error - Vi phạm tiêu chuẩn bắt buộc).

---

3. Thực hành Lệnh Kiểm tra Trạng thái

```
# Kiểm tra phản hồi OCSP thủ công qua OpenSSL
openssl ocsp -issuer ca.crt -cert server.crt -url http://ocsp.kma.internal:8888 -CAfile ca.crt

# Kiểm tra OCSP Stapling của một trang web thực tế
openssl s_client -connect api.kma.internal:443 -status -servername api.kma.internal < /dev/null
```

---

4. Tài liệu Tham khảo Mở rộng

1. **RFC 6960 (OCSP), RFC 6066 (TLS Extensions), RFC 6962 (Certificate Transparency).**
2. **Ben Laurie, Adam Langley, Emilia Kasper:** *Certificate Transparency*, ACM Queue, 2014.